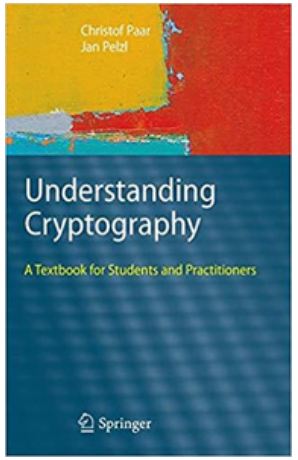
COM/BLM 426
BİLGİ GÜVENLİĞİ

Asst. Prof. Dr. Bulent TUGRUL
btugrul@eng.ankara.edu.tr

Slides are mainly based on:

Understanding Cryptography: A Textbook for Students and Practitioners



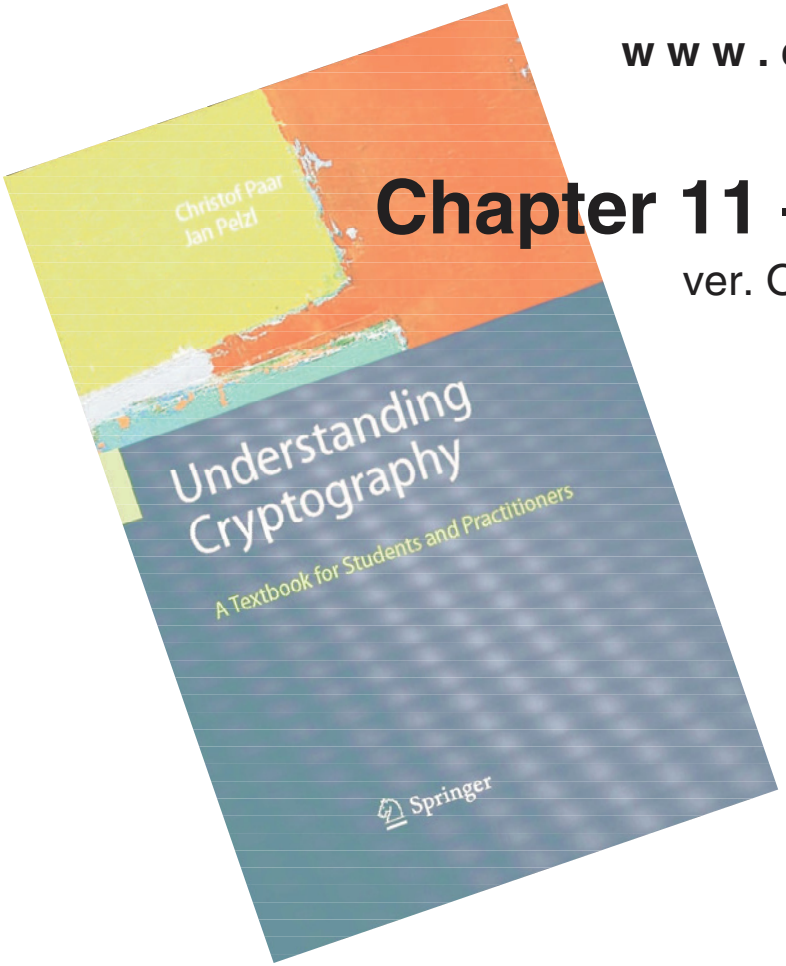
by ChristofPaarand Jan Pelzl

Springer, 1st Edition, 2010

Understanding Cryptography –A Textbook for Students and Practitioners

by Christof Paar and Jan Pelzl

w w w . crypto-textbook. com



Chapter 11 – Hash Fonksiyonlar

ver. October 29, 2009

These slides were prepared by Stefan Heyse and Christof Paar and Jan Pelzl

Bazı yasal bilgiler (sorry): Kullanım Şartları

- Slaytlar ücretsiz olarak kullanılabilir. Slaytların tüm telif hakları Christof Paar ve Jan Pelzl'e aittir.

- Eşlik eden "Understanding Cryptography" kitabının başlığı (Springer tarafından) ve yazarların isimleri her slaytta yer almalıdır.

- Slaytlar değiştirilirse, kitap yazarlarına ve kitap başlığına ilişkin uygun atıflar slaytlarda yer almalıdır.

- Yazarların yazılı izni olmadan slaytların tamamının veya bir kısmının basılı olarak çoğaltılmasına izin verilmez.

Bu Bölümün İçeriği

- Neden Hash(karma) fonksiyonlara ihtiyacımız var?
- Nasıl çalışır?
- Güvenlik özellikleri
- Algoritmalar
- Örnek: Güvenli Hash(Karma) Algoritması SHA-1

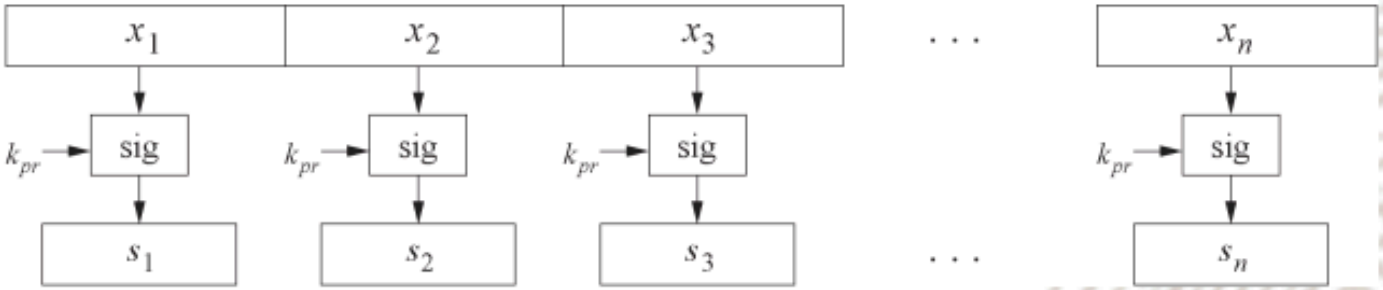
Bu Bölümün İçeriği

- **Neden Hash(karma) fonksiyonlara ihtiyacımız var?**
- Nasıl çalışır?
- Güvenlik özellikleri
- Algoritmalar
- Örnek: Güvenli Hash(Karma) Algoritması SHA-1

Motivasyon

Problem:

Uzun mesajların basitçe imzalanması, aynı uzunlukta bir imza oluşturur.



- Üç Sorun
- Hesaplama yükü
- Mesaj yükü
- Güvenlik sınırlamaları
- Daha fazla bilgi için “Understanding Cryptography” kitabının 11.1. bölümüne bakın.

Çözüm:

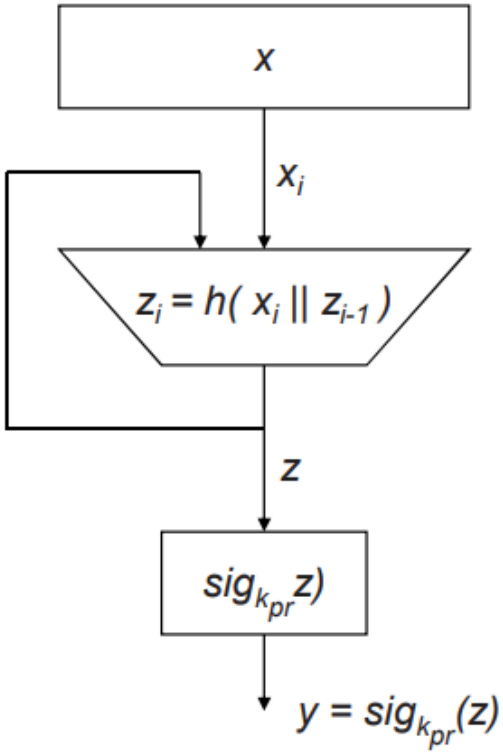
Mesajın tamamını imzalamak yerine, yalnızca özetini (=hash değerini) imzalayın.

Bu da güvenlidir, ancak çok daha hızlıdır.

Gerekli:

Hash Fonksiyonlar

Hash Fonksiyonlu Dijital İmza



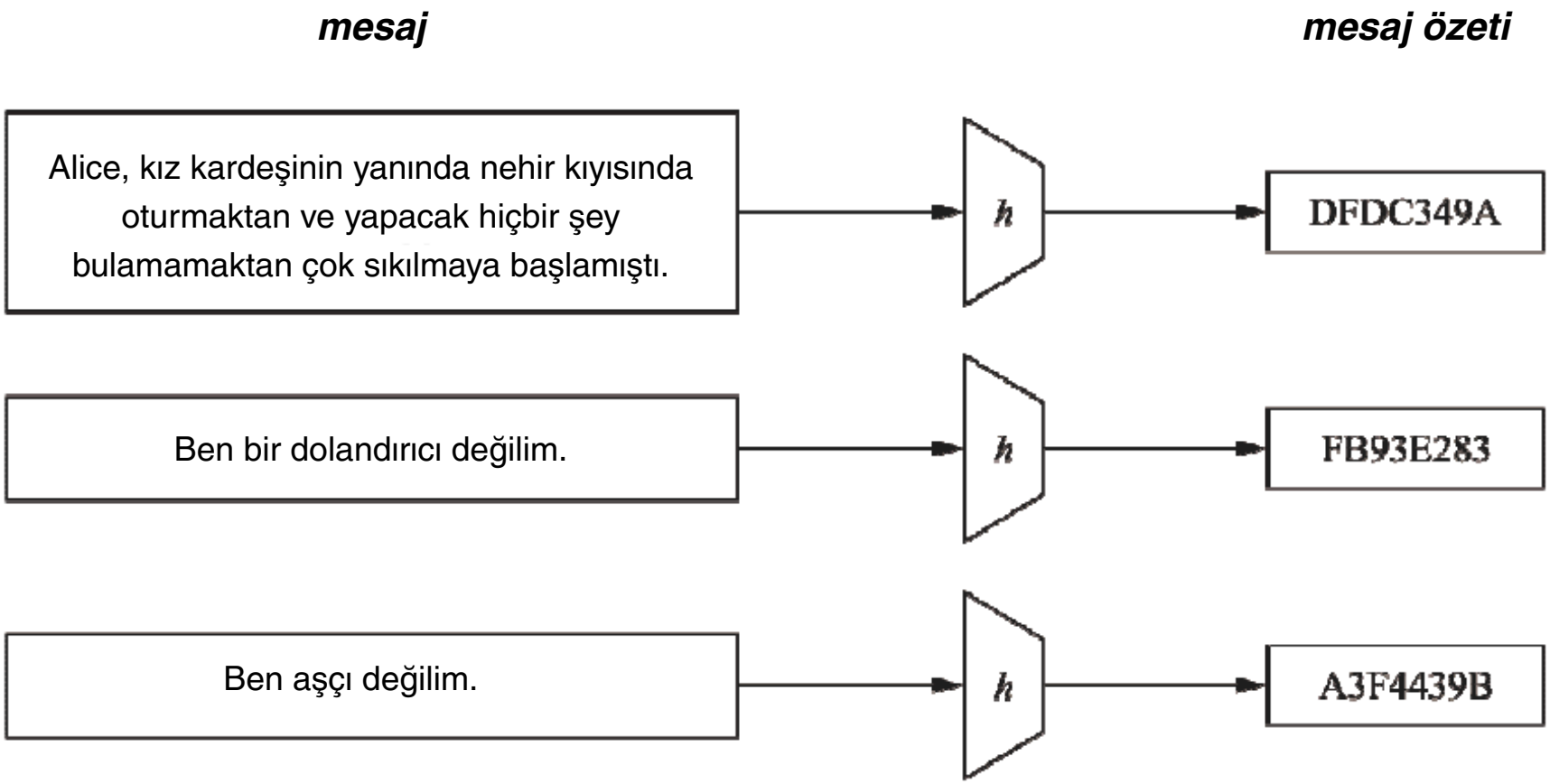
Notlar:

- *x'in uzunluğu sabittir.*
- *z ve y'nin uzunluğu sabittir.*
- *z ve x'in uzunlukları genellikle eşit değildir.*
- *h(x) bir anahtar gerektirmez.*
- *h(x) herkese açıktır.*

Hash Fonksiyonlu Dijital İmzalar için Temel Protokol:

Alice		Bob
	$\xleftarrow{K_{pub}}$	
		$z = h(x)$ $s = sig_{K_{pr}}(z)$
	$\xleftarrow{(x,\ s)}$	
$z' = h(x)$ $ver_{K_{pub}}(s,z')=true/false$		

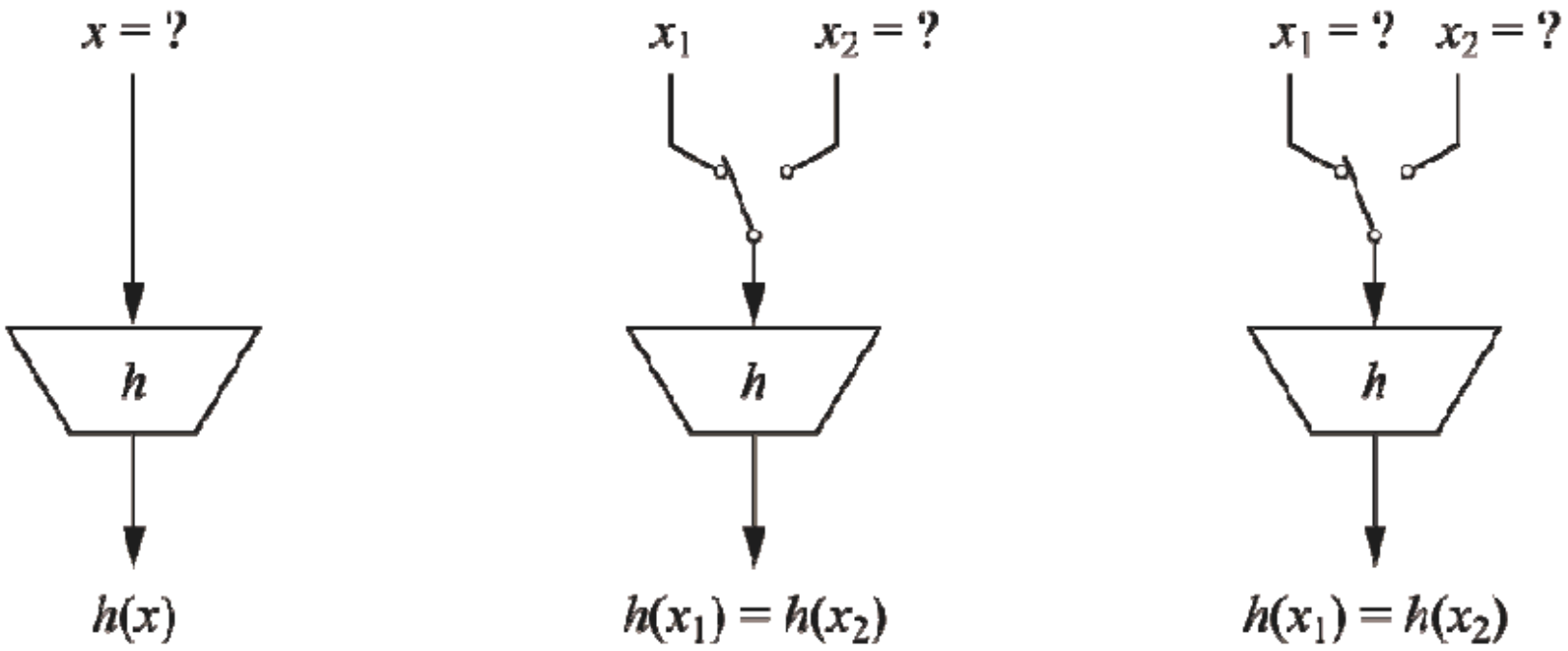
Hash Fonksiyonlarının Temel Girdi-Çıktı Davranışı



Bu Bölümün İçeriği

- Neden Hash(karma) fonksiyonlara ihtiyacımız var?
- Nasıl çalışır?
- **Güvenlik Özellikleri**
- Algoritmalar
- Örnek: Güvenli Hash(Karma) Algoritması SHA-1

Hash Fonksiyonlarının Üç Güvenlik Özelliği



preimage resistance

ön görüntü direnci

second preimage resistance

ikinci ön görüntü direnci

collision resistance

çarpışma direnci

Hash İşlevleri: Güvenlik Özellikleri

- **Ön görüntü direnci:** Belirli bir z çıkışı için, $h(x) = z$ olacak şekilde herhangi bir x girişi bulmak imkansızdır, yani h(x) tek yönlüdür.
- **İkinci ön görüntü direnci:** x_1, ve dolayısıyla $h(x_1)$, verildiğinde, $h(x_1) = h(x_2)$ olacak şekilde herhangi bir x_2 bulmak hesaplama açısından imkansızdır.
- **Çarpışma direnci:** $h(x_1) = h(x_2)$ olacak şekilde herhangi bir $x_1, \neq x_2$ çifti bulmak hesaplama açısından imkansızdır.

Hash Fonksiyonları: Güvenlik

Çarpışma direncinin sorunların çoğuna neden olduğu ortaya çıktı.

- %50 olasılıkla bir çarpışma bulmak ne kadar zordur
- İlgili Problem: İki kişinin doğum gününün %50 olasılıkla aynı olması için kaç kişiye ihtiyaç vardır?
- Hayır! 365/2=183 değil. 23 kişi yeterli! Buna doğum günü paradoksu denir (Arama yaklaşık$\approx\sqrt{2^n}$adım sürer).
- Daha fazla bilgi için Understanding Cryptography kitabının 11.2.3. Bölümüne bakın.
- Bu paradoksu çözmek için, hash fonksiyonlarının en az 160 bitlik bir çıktı boyutuna ihtiyacı vardır.

Bu Bölümün İçeriği

- Neden Hash(karma) fonksiyonlara ihtiyacımız var?
- Nasıl çalışır?
- Güvenlik Özellikleri
- **Algoritmalar**
- Örnek: Güvenli Hash(Karma) Algoritması SHA-1

Hash Fonksiyonları: Algoritmalar

Hash Algoritmaları

Özel Algoritmalar,
ör. MD5 - family

blok şifreleme
algoritmalarına dayalı

- **MD5 -** family
- **SHA-1**: Çıkış - 160 Bit; Giriş - 512 bitlik mesaj parçaları x;

  İşlemler - bit düzeyinde AND, OR, XOR, tamamlayıcı ve döngüsel kaydırmalar.
- **RIPE-MD 160:** Çıkış - 160 Bit; Giriş - 512 bitlik mesaj parçaları x;

  İşlemler – SHA-1'deki gibi, ancak iki işlem paralel olarak ve her turdan

  sonra bunların kombinasyonları.

Bu Bölümün İçeriği

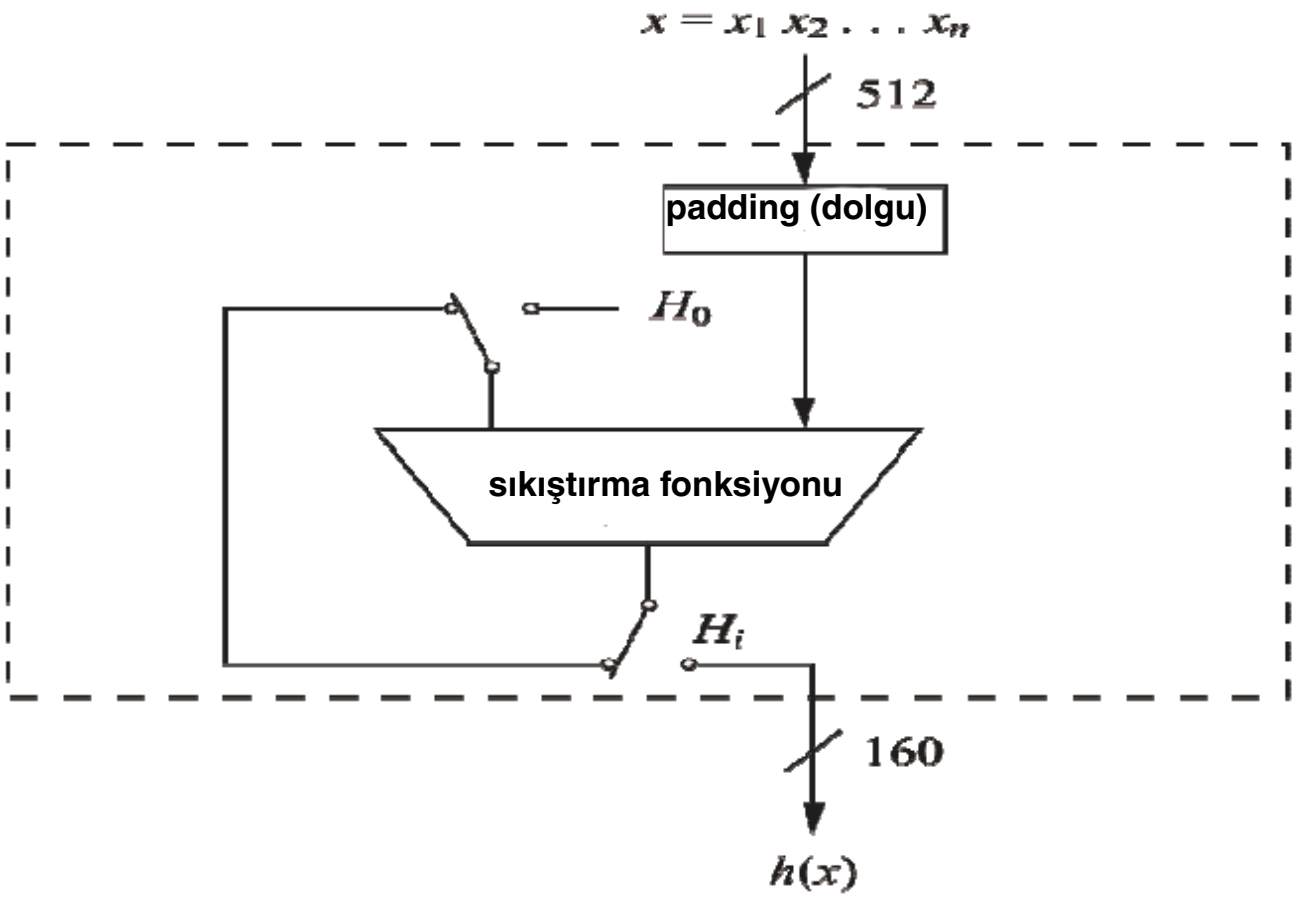
- Neden Hash(karma) fonksiyonlara ihtiyacımız var?
- Nasıl çalışır?
- Güvenlik Özellikleri
- Algoritmalar
- **Örnek: Güvenli Hash(Karma) Algoritması SHA-1**

SHA-1

- MD-4 ailesinin bir parçası.
- Merkle-Dåmgard yapısına dayanmaktadır.
- Maksimum 264 bit uzunluğundaki bir mesajdan 160 bit çıktı üretir.
- Yaygın olarak kullanılır (bazı zayıf yönleri bilinmesine rağmen) bilinmektedir.

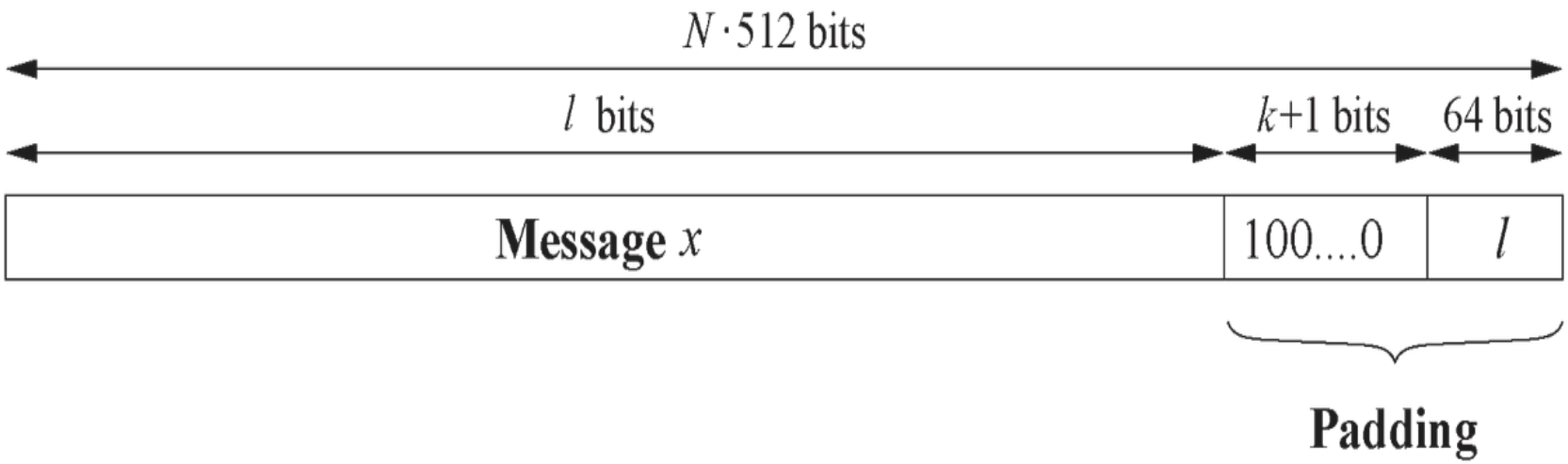
SHA-1 Yüksek Seviye Diyagramı

- Sıkıştırma Fonksiyonu, her biri 20 turdan oluşan dört aşamaya bölünmüş 80 turdan oluşmaktadır.



SHA-1: Padding (Dolgu)

- Mesaj x'in 512 bitin katı bir boyuta sığması için doldurulması gerekiyor.
- $k \equiv 512 - 64 - 1 - l = 448 - (l + 1) \bmod 512$.



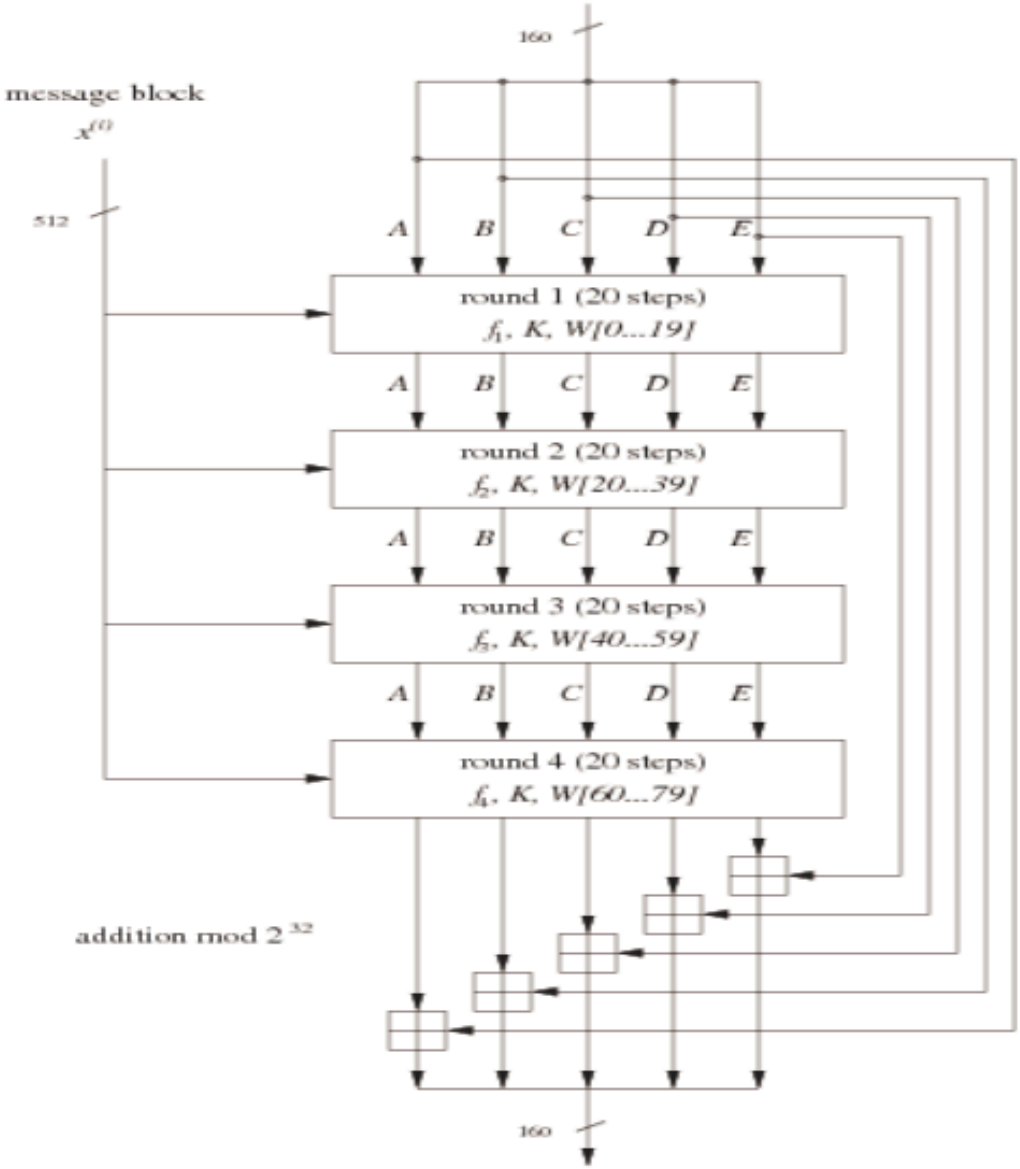
SHA-1: Hash Hesaplama

- Her bir mesaj bloğu x_i , her biri 20 turdan oluşan dört aşamada işlenir.

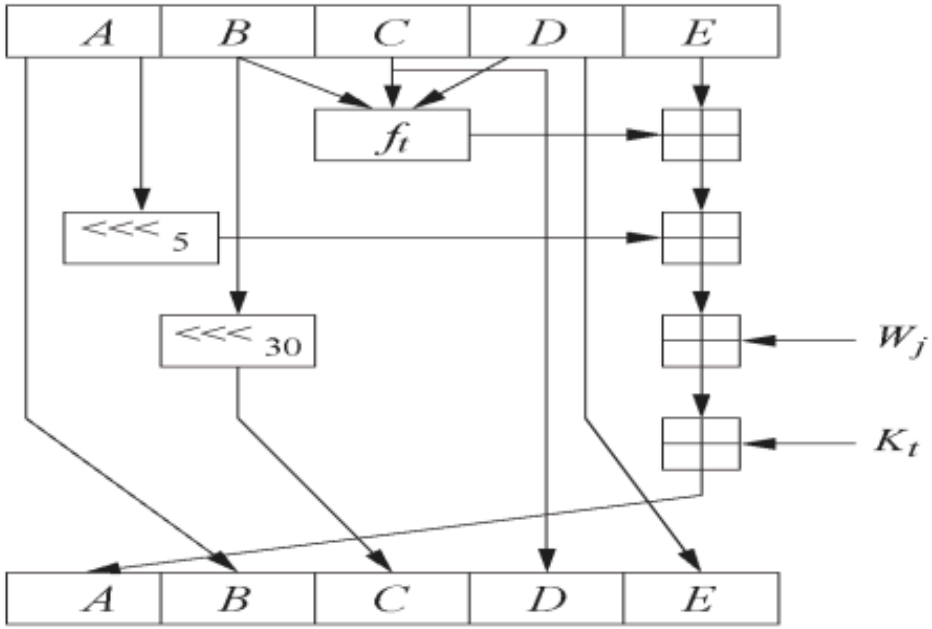
SHA-1 kullanım alanları:

- 80 turdan her biri için 32 bitlik bir kelime W0, W1, ..., W79 hesaplayan bir mesaj zamanlama programı.
- 32 bit boyutunda beş çalışma kaydedici A, B, C, D, E
- Beş adet 32 bitlik kelimeden oluşan bir karma değer $H_i^{(0)}, H_i^{(1)}, H_i^{(2)}, H_i^{(3)}, H_i^{(4)}$
- Başlangıçta, karma değeri başlangıç değeri olan H_0 'ı tutar ve her bir mesaj bloğunun işlenmesinden sonra yeni bir karma değeriyle değiştirilir.
- Son karma değeri H_n , SHA-1'in çıktısı h(x)'e eşittir.

SHA-1: Dört Aşamasının Tamamı



SHA-1: Bir Merminin İç Yapısı



Stage t	Round j	Constant K_t	Function f_t
1	00…19	K=5A827999	$f(B,C,D)=(B \wedge C) \vee (\overline{B} \wedge D)$
2	20…39	K=6ED9EBA1	$f(B,C,D)=B \oplus C \oplus D$
3	40…59	K=8F1BBCDC	$f(B,C,D)=(B \oplus C) \vee (B \oplus D) \vee (C \oplus D)$
4	60…79	K=CA62C1D6	$f(B,C,D)=B \oplus C \oplus D$

Öğrenilen Dersler: **Hash-Funktionen**

- Hash fonksiyonları anahtarsızdır. Hash fonksiyonlarının en önemli iki uygulaması, dijital imzalarda ve HMAC gibi mesaj doğrulama kodlarında kullanılmasıdır.

- Hash fonksiyonları için üç güvenlik gereksinimi, tek yönlülük, ikinci ön görüntü direnci ve çarpışma direncidir.

- Çarpışma saldırılarına dayanabilmek için hash fonksiyonlarının en az 160 bit çıktı uzunluğuna sahip olması gerekir; uzun vadeli güvenlik için 256 bit veya daha fazlası tercih edilir.

- Yaygın olarak kullanılan MD5 güvensizdir. SHA-1'de ciddi güvenlik zafiyetleri bulunmuştur ve hash fonksiyonunun aşamalı olarak kaldırılması gerekir. SHA-2 algoritmalarının tümü güvenli görünmektedir.

- Devam eden SHA-3 yarışması, birkaç yıl içinde yeni standartlaştırılmış hash fonksiyonlarıyla sonuçlanacaktır.